Lab Implementation Guide

How to use the guide

The analyst reads reports. The engineer reads maintenance instructions. The unassigned user is denied. Follow the assignment for required outcomes.

Follow the five phases in order: infrastructure, identity and endpoints, access controls, monitoring and recovery, then validation and submission. Read each procedure first. Obtain approval before each stage A-L, covering assets, changes, validation and rollback. Use the architecture and technical reference for detail.

Use private copies of the five Office files, numbered **01-05**. Record observations, dates and private evidence references in the named sections. Use synthetic users and separate lab passwords; keep raw evidence private. Leave unperformed checks **NOT TESTED**. If a result differs, stop the affected work, follow its recovery plan and log it in **Deliverable 04 > Issue Log**.

Phase 1: Prepared Infrastructure

Verify the Dell Precision 5820 with Proxmox, HP desktop with physical OPNsense, TP-Link TL-SG108E switch and GL.iNet Beryl AX upstream router.

Before you start: Have read-only stage A approval, the private network map and backup/recovery record, and Dell/HP console access. Missing map, version or recovery details mean stop. Changes need separate B (host), C (network) or D (firewall) approval; this phase installs nothing.

A. Verify the lab equipment and VM resources

WHERE

Dedicated lab administrator computer; Dell and HP consoles. Use private management addresses.

STEPS

1. Sign in at both consoles. Compare device identities and cables with the private map. Confirm the original Windows disk, data and services remain protected and their recovery record is available.
2. Open **Proxmox > Dell node > Summary**, then storage > **Summary**. Compare CPU, memory and usable storage with the capacity budget and reserves.
3. Select **DC1**, **WIN1** and **APP1 > Hardware** in turn. Compare processors, memory and disk allocations with that budget. Physical OPNsense on HP is outside these guest totals.
4. Compare the GUI inventory with device labels and the private physical/firmware record. Record a difference before continuing.

CHECK	Exactly three workload VMs; allocations total 6 vCPU / 16 GiB RAM / 160 GiB disks. Measured capacity also covers host, free-space and temporary-restore reserves. Both consoles and recovery records are available.

RECORD	**Deliverable 01 > Hardware & Readiness**, **Virtual Machines** and **Resource Allocation**. Enter observations and evidence references.

B. Verify network zones and management access

WHERE

Administrator computer: Proxmox, HP OPNsense and switch web pages.

STEPS

1. Open **OPNsense > Interfaces > Assignments**. Match Management, Corporate and Restricted to the HP ports and private map.
2. Open **Proxmox > Dell node > System > Network**. Compare bridge ports, addresses and VLAN-aware settings with the approved relationships.
3. Open each VM's **Hardware > Network Device**. Match bridge and VLAN tag to the map: DC1/WIN1 in Corporate; APP1 in Restricted, with one zone NIC each.
4. Open the switch's **VLAN > 802.1Q VLAN** and **802.1Q PVID Setting** pages. Compare tagged/untagged membership and port defaults with the map; change nothing.
5. Inspect the management restrictions: named administrator sources/services, effective host/device rules, supported multifactor authentication and console recovery.

> **CHECK** Three zones reach HP; no switch/host route bypasses OPNsense. Workload bridges have no host address. Only the dedicated path reaches management; APP1's approved overlay is the sole extra interface.

> **RECORD** **Deliverable 01 > Network Zones** and **Allowed Network Flows**.

C. Verify isolation and required network access

WHERE

Administrator computer: read-only Windows, Beryl AX and firewall/host views.

STEPS

1. Open Windows **Settings > Network & internet > Advanced network settings**. Compare adapters with the isolation record; flag extra Wi-Fi, VPN or shared connections.
2. In Beryl AX **INTERNET**, inspect **Ethernet**, **Repeater**, **Tethering** and **Cellular**. Keep upstream disconnected until independent isolation and egress are approved.
3. Compare FF-01 through FF-08 with effective firewall/host rules, states, NAT and listeners. Use the flow checklist; unlisted access stays denied.
4. Complete the IPv4/IPv6, route and trust checks. GUI inspection alone does not prove home/production isolation.
5. For separately approved active validation, use lab-owned mocks. Record allowed and denied behavior plus policy/log evidence under FWT-01/FWT-02. Never probe home or production.

> **CHECK** Map/flows match. FWR-01/FWR-02 need FWT-01/FWT-02 evidence and second observations. Unperformed active checks stay **NOT TESTED**.

> **RECORD** **Deliverable 01 > Allowed Network Flows** and **Deliverable 03 > Test Cases**.

Before Phase 2: Resolve mismatches; carry pending checks forward. For unexpected connectivity, stop and use console isolation/recovery.

Phase 2: Identity and Endpoint Security

DC1 manages lab Windows accounts; WIN1 uses them; APP1 has a protected Linux baseline. Coverage: FWR-03/FWR-04 and FWT-03/FWT-04.

Before you start: Approvals: E for directory work, F for endpoint settings; missing workload creation also needs the applicable host/network approval. Have the private identity/network plan, approved media, versions, policy values and console recovery. Keep lab DNS, time, credentials and identities separate from home/production; create no trust or identity synchronization.

A. Verify or create the three workload VMs

WHERE

Proxmox > Dell node, then each guest's **Hardware** and **Console**.

STEPS

1. Find **DC1**, **WIN1**, **APP1**. Verify existing guests; create a missing guest only with approval and the guest profiles. Protect the original Windows disk/services.
2. Check CPU / RAM / disk: **DC1 2 / 6 GiB / 64 GiB; WIN1 2 / 6 GiB / 64 GiB; APP1 2 / 4 GiB / 32 GiB**; retain host/recovery reserves.
3. In **Hardware > Network Device**, match the private bridge/tag/MAC map: one zone NIC each; Corporate for DC1/WIN1, Restricted for APP1. Management stays separate; physical OPNsense is on HP.
4. Open **Console**. Verify name, supported OS/build, approved media, private recovery and lawful offline update/activation. Windows 11 needs supported CPU, UEFI/Secure Boot and TPM 2.0; no bypass.

CHECK	Three workload VMs; own virtual disks; totals 6 vCPU / 16 GiB / 160 GiB. Resolve a mismatch through approved console recovery.
RECORD	**Deliverable 01 > Virtual Machines / Resource Allocation**; **02 > Implementation Overview**. Include update/activation gaps.

B. Configure DC1 and Active Directory

WHERE

DC1 console, approved administrator: **Server Manager**. Active Directory (AD) manages Windows users.

STEPS

1. Open **Local Server > Ethernet > adapter Properties > Internet Protocol Version 4 > Properties**. Set approved Corporate address/mask/gateway and **DC1 as DNS**, without external alternates. Check name/MAC/time.
2. Verify an existing directory; otherwise use **Manage > Add Roles and Features > Role-based or feature-based installation > DC1 > Active Directory Domain Services**. Include tools; install.
3. For a new forest only: notification flag > **Promote this server to a domain controller > Add a new forest**. Enter **ad.lab.test**, retain DNS and approved functional levels; store the DSRM recovery credential privately.
4. Review prerequisites and paths, resolve warnings, install and restart.
5. Open **Tools > DNS > DC1 > Forward Lookup Zones > ad.lab.test**. Check host/service records and forest/controller health, including SYSVOL/NETLOGON.

CHECK	Forest/controller/DNS work. Role installation alone is insufficient. On failure inspect DNS/time/prerequisites; use supported directory recovery.
RECORD	**Deliverable 02 > Active Directory and User Roles**; **03 > Test Cases**, FWT-03.01-.03.

C. Create lab users and groups, then join WIN1

WHERE

DC1 **Server Manager > Tools > Active Directory Users and Computers**; WIN1 console.

STEPS

1. In **ad.lab.test**, verify or create the approved organizational units (OUs) or containers for users, groups, privileged identities and member computers. Keep DC1 in **Domain Controllers**; do not assume **Users** is the approved folder.
2. In the user folder select **New > User**. Create missing **ava**, **eli**, **uma**, with unique private passwords and approved first-logon choices. Verify the separate named administrator in its privileged folder.
3. Select **New > Group** in the group folder: **Global**, **Security**. Create/verify **LabReaders**, **LabMaintainers**, **LabAdmins**. In **Properties > Members > Add**, use **Check Names**: Readers = ava/eli; Maintainers = eli; Admins = separate administrator only.
4. Inspect each user's **Member Of** and each group's **Members**. Keep uma outside both application-related groups and all three standard users outside privileged groups. Assign only approved administrator rights; group names grant none.
5. Open DC1 **Tools > DNS > Forward Lookup Zones > ad.lab.test > New Host (A or AAAA)**. Add/verify **app**, IPv4 A record, with APP1's approved private address.
6. On WIN1 set its approved Corporate address/gateway and DC1-only DNS. Open **System Properties > Computer Name > Change > Domain**, enter **ad.lab.test**, use the prompted join credential and restart. Move WIN1 to the approved computer OU on DC1.
7. Sign in on WIN1 as **ava@ad.lab.test**. Verify lab DNS, domain membership and policy using the join checks. Test eli/uma logon within approval.

CHECK	Three standard users, three role groups and one separate privileged administrator; memberships and standard logon agree. AD groups do not assign Apache roles. On failure, inspect DNS/time/membership and correct only the approved object; never elevate a standard user.
RECORD	**Deliverable 02 > Active Directory and User Roles**; **03 > Test Cases**, FWT-03.01-.03. Later application roles use distinct passwords; six access cases and revocation remain required.

D. Apply Windows security policies

WHERE

DC1 **Server Manager > Tools > Group Policy Management**; DC1/WIN1 security consoles.

STEPS

1. Link the account-policy Group Policy Object (GPO) at **Domains > ad.lab.test**. Enter approved password/lockout values.
2. Link WIN1's endpoint GPO to its computer OU: Microsoft Defender enabled; all Windows firewall profiles **On**, inbound **Block**; reviewed exceptions only.
3. Apply WIN1 logon auditing and a separate DC1 GPO at **Domain Controllers**, using the exact auditing paths.
4. In **Windows Defender Firewall with Advanced Security > Inbound Rules**, scope AD/DNS/time rules. Remove approved broad overlaps; FF-02 needs same-zone host enforcement.
5. Inspect winning policy, protection and updates on both targets. Check WIN1 **Administrators**; run the standard-user denial/admin control.

CHECK	Settings and privileges match approval; policy/log evidence supports behavior. On failure restore changed pilot settings at console; keep protections enabled.

RECORD	**Deliverable 02 > Windows and Linux Endpoint Controls**; **03 > Test Cases**, FWT-03/FWT-04.

E. Configure APP1 networking and host protection

WHERE

APP1 Proxmox **Console**, approved sudo administrator. APP1 stays outside AD.

STEPS

1. Match interface MAC with **Hardware > Network Device** and the private map. Inspect addresses/routes/DNS/rules; save recovery copies.
2. If needed, edit Netplan: approved private interface/address/gateway, DC1-only DNS. Check syntax, use the timed trial and verify rollback.
3. Verify lab-only time, without public/corporate DNS/time fallback or another backend.
4. Apply nftables policy: default-deny input/forward, exact WIN1/admin HTTPS, IPv4/IPv6 restrictions; future overlay on APP1 alone.
5. Use initial load or scoped atomic replacement. Preserve other tables. Verify rules/routes/services/reboot persistence; test HTTPS permit/deny when its listener exists.

CHECK	Configuration/state agree; forwarding is off. On failure restore saved files at console. Never flush all rules or add another firewall manager.

RECORD	**Deliverable 02 > Windows and Linux Endpoint Controls**; **03 > Test Cases**, FWT-04. Include second observations.

Before Phase 3: Compare directory/logon/DNS/policy/privilege evidence. Unperformed FWT-03/FWT-04 checks, including later app cases, stay **NOT TESTED**. Resolve failures through approved console recovery; directory rebuild/snapshot rollback needs separate supported recovery approval.

Phase 3: Zero Trust Access Controls

Let approved users reach the right HTTPS page, then prove that removed permissions stop working. Coverage: FWR-03/05/06 and FWT-03/FWT-05/FWT-06.

Before you start: Approvals: G for certificates/trust, H for Apache, I for remote access; E also covers AD revocation. Have private versions/network/identity records, saved configurations and console recovery. External access needs independently isolated, approved egress. Use the linked references; missing scope means stop.

A. Create and verify HTTPS certificates

WHERE Approved existing offline signing workstation: terminal; APP1 Proxmox **Console**; WIN1 lab browser.

STEPS

1. On the offline signer, create the encrypted CA key and 365-day public root in a new private directory. Keep the key offline and passphrase in recovery custody; add no CA VM/service.
2. On APP1 create its private server key and certificate signing request. Transfer only the request to the signer.
3. On the signer, sign one 90-day leaf for **app.ad.lab.test**. Verify subject alternative name (SAN), serverAuth, chain/constraints, dates and remaining validity; leave domain time unchanged.
4. Transfer public certificates to APP1; keep its key root-only. After B starts HTTPS, record WIN1's untrusted rejection, then import only the fingerprint-checked public root into its approved lab store and retry. Never bypass warnings.

CHECK	Correct chain/name/dates; untrusted rejection then normal trusted HTTPS. No home/production trust changes. On failure stop and use certificate recovery.
RECORD	**Deliverable 02 > HTTPS Certificate Configuration**; **03 > Test Cases**, FWT-05: public properties, custody/scope, browser evidence. **02 > Implementation Results and Limitations**: certificate-revocation services excluded.

B. Configure the Apache application and accounts

WHERE APP1 Proxmox **Console**, approved sudo administrator and root editor; WIN1 browser.

STEPS

1. Save settings. Use approved Apache 2.4/password-utility packages/media; create synthetic pages at **/reports/** and **/maintenance/**.
2. Create/verify separate test accounts **ava**, **eli**, **uma**, with distinct application passwords. Create the password file once; never overwrite it to add a user.
3. Set manually assigned roles in **/etc/labapp/groups**: **LabReaders: ava eli**; **LabMaintainers: eli**; uma neither. AD provides Windows logon: no application single sign-on or automatic synchronization, no fourth app administrator.
4. Apply HTTPS/group configuration; require each page's group. Disable HTTP/reviewed default sites; syntax-check before restarting.
5. Verify Apache active, **TCP 443 only**, protected key/password/group files, no extra service. Complete A's trust sequence; preserve FF-03 firewall/host restrictions.

CHECK	HTTPS/group checks work. On failure inspect DNS/TLS/files and restore saved settings. Never use a generic authenticated-user allow.
RECORD	**Deliverable 02 > Application Accounts and Permissions**; **03 > Test Cases**, FWT-03.10/FWT-05: versions, effective files, roles and evidence. Exclude passwords/hashes.

C. Test the six application access cases

WHERE WIN1 **Browser > Developer tools > Network**; APP1 console: Apache logs.

STEPS

1. Use a fresh browser context per user and valid application credentials. Close all private windows between users.
2. Disable cache; reload each exact path. Confirm the actual server request/status using the evidence method.
3. Compare all six requests with Apache logs/effective groups; keep eli's working maintenance context for D.

Case	Account	Page	Expected HTTP result
C01	ava	/reports/	ALLOW / 200
C02	ava	/maintenance/	DENY / authenticated 403
C03	eli	/reports/	ALLOW / 200
C04	eli	/maintenance/	ALLOW / 200
C05	uma	/reports/	DENY / authenticated 403
C06	uma	/maintenance/	DENY / authenticated 403

CHECK A failed login/401 or unreachable service is not role denial. On failure preserve evidence; inspect account/group/inherited rules.

RECORD **Deliverable 03 > Test Cases**, FWT-03.04-.09; link from **02 > Six Application Access Tests**. FWT-03.01-.03 and mapping/revocation .10-.13 remain mandatory.

D. Revoke an application permission

WHERE APP1 root editor; DC1 **AD Users and Computers**; WIN1 browser.

STEPS

1. Confirm eli's maintenance access; save groups and change time against a separate observer clock.
2. In **/etc/labapp/groups**, remove eli from **LabMaintainers**, keeping **LabReaders: ava eli** and ownership/mode.
3. Under E approval remove eli on DC1: approved **LabMaintainers > Properties > Members**. Record both changes; AD membership does not update Apache.
4. Disable cache; force a **/maintenance/** server request in eli's existing authenticated browser, then a fresh context with valid app credentials. Compare both with Apache logs/effective groups; check reader access.

CHECK Both maintenance requests return authenticated 403; reader permission stays. On failure inspect files/cache/inheritance. Restore permissions only with recorded explicit test/recovery approval.

RECORD **Deliverable 03 > Test Cases**, FWT-03.10-.13; **02 > Access Revocation**. Record changes, request/denial times, observed elapsed time and cache/state treatment; no revocation-time SLA.

E. Configure, test and revoke Tailscale access

WHERE Separate lab **Tailscale admin console > Access controls / Machines**; APP1 console; one approved existing Windows remote client.

STEPS

1. Verify independent isolation, identities, MFA and recovery before external egress. The client must have no direct zone route to APP1. Missing prerequisites leave FWT-06 **NOT TESTED**.
2. Save the lab policy; apply the explicit deny-all baseline before enrollment. Inspect every additive grant/ACL, SSH rule and tag owner; a blank policy is insufficient.
3. Enroll APP1 and the existing client with separate approved lab identities. Inspect device records. Keep subnet routes, exit node, Tailscale SSH, Funnel, Serve and public sharing off; use no home/production identity or trust.
4. Apply the exact client-to-APP1 TCP 443 grant; review enrolled addresses privately. Map app.ad.lab.test to APP1's overlay address, approve only lab-root trust, and verify independent APP1 host rules/forwarding. FF-06 adds no DC1, WIN1, Proxmox or OPNsense access.
5. Test approved HTTPS, unauthorized identity and wrong listening port/resource. Use working positive controls and vendor/device/host/Apache evidence. A closed port or broken DNS is insufficient. The Phase 5 mock dependency needs separate scope; do not broaden grants.
6. Restore the approved context through its authorized sequence; confirm working HTTPS. Record time, then remove the client grant and exact device authorization, keeping APP1 intact.
7. Force new server requests in the existing browser and a fresh context. Both must fail; compare policy/device/log state, observed denial time and cache/connection-state treatment. Re-enrollment or permission restoration needs approval.

CHECK	Only approved APP1 HTTPS works; unauthorized/wrong-port and both revoked contexts deny. OPNsense alone cannot prove overlay enforcement. On failure stop remote access and use deny-all/device recovery.
RECORD	**Deliverable 03 > Test Cases**, every FWT-06 subcheck; **02 > Tailscale Remote Access / Access Revocation**. Include evidence, actual elapsed time and final device/policy state; keep identities/addresses/raw logs private.

Before Phase 4: Compare all mandatory FWT-03/FWT-05/FWT-06 subchecks with second observations; missing work stays **NOT TESTED**. Log failures in **04 > Issue Log**. Recover saved app/policy files, lab-only trust and exact remote authorization within approval; preserve key custody and failed evidence.

Phase 4: Monitoring, Automation and Recovery

Explain five security events, repeat one useful local operation and demonstrate APP1 recovery. Coverage: FWR-07/08/09 and FWT-07/FWT-08/FWT-09. Use existing logs and the three workload VMs; HP runs physical OPNsense.

Before you start: J approval covers logs/events; explicit L portions cover automation and recovery. Existing D/H/I/K scopes must cover any mock check; E/H/I cover any final permission changes. Keep raw evidence private. Recovery is **BLOCKED** until the encrypted backend and private isolation plan are approved; no safe port/bridge mapping is supplied here.

A. Collect five security events

WHERE DC1 **Event Viewer**; physical HP **OPNsense** web interface; APP1 Proxmox **Console**; WIN1 sign-in/browser.

STEPS

1. Verify DC1's Kerberos success/failure auditing, approved log-reader rights and selected account's lockout margin.
2. Open **Windows Logs > Security**, **Firewall > Log Files > Live View**, and APP1's Apache logs. Check access, retention/rotation and source clocks.
3. Reuse current matching evidence or perform each approved benign action once. No additional traffic merely to fill a worksheet.

Event	Action and matching source
E01 Directory authentication success	Valid online WIN1 logon; DC1 Security success
E02 Directory authentication failure	One wrong-password attempt, then stop; DC1 Security failure
E03 Application access allowed	ava opens /reports/ with valid app credentials; Apache allow
E04 Application access denied	ava opens /maintenance/ with valid app credentials; Apache role denial
E05 Firewall access denied	One approved request to a known-listening lab target; matching OPNsense block

4. Locate each event by identity, resource, source/destination, service and time. Compare the actual firewall rule or app group; a failed connection alone proves no control.
5. Compare source/observer UTC, record their difference and link each private original. Five distinct categories are required.

CHECK Five attributable records agree with actions and policy. On failure inspect auditing, time filters, logging and listener state; never repeat password guesses, clear logs or disable lockout.

RECORD **Deliverable 03 > Security Events**, E01-E05; **Evidence Index**; **Test Cases**, FWT-07.01-.07/.09. Include actuals, private evidence, versions, operator/date and second observations.

B. Investigate one denied-access event

WHERE Deliverable 03; WIN1 request view; APP1 or physical HP policy/log view.

STEPS

1. Choose E04 or E05. Record who requested which resource/service, client context, source/destination, actual time and outcome.
2. Compare the matching log and effective rule/group; identify the intended enforcing control.
3. Link one working allowed control to that listening service and a second observation. Distinguish correct policy denial from incorrect credentials, broken DNS, stopped service or network failure.
4. Record conclusion, limitations and evidence references. Preserve failures and link any correction/retest in **Deliverable 04 > Issue Log**.

CHECK	The request, intended policy and observed decision agree. If evidence is missing, leave the conclusion unverified; do not infer enforcement from a timeout or change the expectation.

RECORD	**Deliverable 03 > Denied Access Investigation**; link the event, **Evidence Index** and **Test Cases**, FWT-07.08/.09.

C. Run the capacity-summary automation

WHERE WIN1 local **Windows PowerShell**, standard user; an approved existing private directory outside Git.

STEPS

1. Review and save the complete capacity script privately. Preserve its WIN1/ad.lab.test target and path guards; use existing policy/signing, without bypass.
2. Inspect output-directory permissions, reparse points and the existing summary. Capture before-state; only **WIN1-capacity.json** may be replaced.
3. Run once. Compare DeviceID/Size/FreeSpace with **File Explorer > This PC > drive Properties**, using consistent byte units.
4. Run successfully a second time. Compare before/after files and settings; other files, accounts, network and system settings must remain unchanged.
5. Run the safe invalid-target check using only a disposable private copy with its expected hostname changed; retain the real script and verify no summary write.
6. Run the real script's invalid-output-path check. Verify rejection and unchanged summary independently after each negative check.

CHECK	One local fixed-disk query, two successful runs, both safe rejections and separate OS/state observations. On failure stop; correct only approved paths/rights. Do not elevate or widen writes to force success.

RECORD	**Deliverable 03 > Automation Verification**, A01-A07; **Test Cases**, FWT-08.01-.07; **Evidence Index**. Keep the script/output and failure evidence outside Git.

D. Back up APP1 and restore it in isolation

WHERE Dell **Proxmox**; original/restored APP1 **Console**; WIN1 browser; physical HP **OPNsense**; approved encrypted external storage.

STEPS

1. Clear the private recovery prerequisites: exact encrypted backend, separate recovery key, unused temporary ID, space, cleanup and existing isolated path through physical HP. Missing design means **BLOCKED / NOT TESTED**; do not begin the drill.
2. Decide the final application/remote authorization state under E/H/I scope before backup. Record approved changes/retests; retain revoked state if restoration is unapproved.
3. Create and separately protect the APP1 file manifest. Verify external encryption/mount/storage and mountpoint guard; a host directory or snapshot is insufficient.
4. Cleanly shut down original APP1; confirm **Stopped**. Back it up once, inspect archive identity/time/disk coverage and protect the sole archive. Keep the original off throughout restore testing.
5. Start a separate observer clock immediately before confirming Restore to the unused temporary ID. Keep start/live restore off; before console boot disconnect every restored NIC and disable automatic startup. Never overwrite original APP1 or the sole backup.
6. At the disconnected copy's console, stop and disable copied Tailscale. Verify inactive/disabled state and all manifest hashes/content before temporary changes; preserve mismatches.
7. Verify the approved physical-firewall isolation checklist before attaching any restored NIC. Keep home/production and duplicate identities disconnected. Use only named temporary client/firewall changes; no new bridge/VLAN/NIC/port mapping or firewall bypass.
8. Through that isolated WIN1 path, test trusted HTTPS: ava /reports/ allows; ava /maintenance/ denies with valid credentials. Compare Apache/group evidence. Stop the observer clock only after integrity and usable application checks; record actual elapsed time.
9. Disconnect and shut down the copy, then clean up. Restore saved client/rule settings before original startup; verify original HTTPS/roles/approved remote state. Safely lock/detach the encrypted backup into separate custody, with its recovery key stored separately.

CHECK	Backup/restore output, separate clock, file integrity and HTTPS allow/deny agree. On failure leave the copy disconnected, preserve original/sole backup and follow approved recovery; never reconnect broadly or invent a recovery time/PASS.
RECORD	**Deliverable 03 > Backup & Restore**, B01-B10; **Test Cases**, FWT-09.01-.10; **Evidence Index**. Record backup age/time, final state, failures and AD/CA/host/physical-firewall recovery exclusions; issues in **04 > Issue Log**.

Before Phase 5: All FWT-07/08/09 mandatory subchecks and second observations remain required. Missing or blocked evidence stays **NOT TESTED**. Retain private source logs, output and backup; recover only approved changes. Engineering results and owner acceptance are separate.

Phase 5: Validation and Final Submission

Outcome: ten fully evidenced engineering results, five clear submissions and a separate owner acceptance decision. Approvals: K validation and remaining L closeout. Test: FWT-10; requirement: FWR-10. Earlier observations can be reused only while they describe the current configuration and meet every mandatory check.

Step 24 - Prepare the permitted and denied network checks

Purpose and location: under the exact D/H/I/K validation scope, use existing lab guests and listeners to distinguish a real deny from a broken service. These are subchecks of FWT-01/FWT-02/FWT-06, not extra exercises or permanent resources. Freeze source, target, identity, single destination port, expected result, observer, stop condition and cleanup before each check.

1. Establish a working allowed control: WIN1 opens APP1 HTTPS and the dedicated administrator opens the lab management interfaces. Compare the active listener to the relevant permit/policy. If the control fails, diagnose it before the negative test.
2. For FWT-01's protected-boundary mock, use **APP1's lab address**, never a real protected address. Under the approved temporary rule scope, add a separate **MOCK_PROTECTED** alias containing that lab address and a logged Corporate rule blocking **WIN1 > MOCK_PROTECTED > TCP 443**, ahead of FF-03. Keep real protected networks physically absent. Make the one frozen request, compare its denial with this exact rule/counter, remove only the temporary mock rule/alias, and confirm normal FF-03 access again. The real isolation conclusion also requires cable/routes/trust review; the mock is one behavioral observation.
3. For FWT-02 unlisted inter-zone access, use DC1 as the source to the known listening APP1 TCP 443 while only WIN1 has FF-03 permission. For ordinary-user management denial, use WIN1 to Proxmox TCP 8006 with the dedicated-admin control working. Compare the intended network/host deny, not just a failed password prompt.
4. For FWT-06's wrong listening port, temporarily configure Apache's existing APP1 service to listen on one approved unused mock port such as **8443**. This example is conditional on that exact port/scope approval. Save the site/ports files, add the following separate temporary file in the approved Ubuntu Apache configuration directory, enable it, syntax-check and reload as in Step 16. No new page, account or software is needed.

CONFIGURATION CHANGE - APP1 root editor, temporary /etc/apache2/conf-available/lab-mock.conf; approved 8443 mock only. Configuration content, not commands; reuse the synthetic document tree and deny page content. The positive control needs only a listening TCP connection:

```
Listen 8443
<VirtualHost *:8443>
    ServerName app.ad.lab.test
    DocumentRoot "/srv/labapp"
    <Directory "/srv/labapp">
        Require all denied
    </Directory>
</VirtualHost>
```

Check before enabling: the port is unused, the exact temporary listener has approval, and no new Tailscale grant or ordinary-user permit is added.

CONFIGURATION CHANGE followed by READ-ONLY - APP1 console, sudo/root, temporary mock scope. Enable only that named configuration and verify syntax/listening. No placeholders once 8443 is approved:

```
sudo a2enconf lab-mock
sudo apachectl configtest
sudo systemctl reload apache2
sudo ss -lntp
```

Check: proceed to reload only after Syntax OK. Confirm Apache listens on 8443; if parsing fails, disable the named mock configuration and restore the saved files before reloading.

5. Use Step 12's console-only replacement transaction to add **ip saddr LAB_ADMIN_IP tcp dport 8443 counter accept** after the physical-source HTTPS permit and before the input chain's closing brace; retain the tailscale0 drop and final drop policy. Replace the source with the exact dedicated administrator IPv4 address. OPNsense's corresponding temporary FF-05 Management permit must name the same source/destination/port. Keep the vendor TCP-443-only grant unchanged. Confirm the administrator reaches the listener, then make the frozen remote wrong-port request; it must be denied. Match the actual vendor/host rule state/counter; do not claim one layer caused the deny without evidence.
6. After the recorded check, disable only **lab-mock** with the Ubuntu **a2disconf lab-mock** service helper, syntax-check, reload and confirm 8443 is no longer listening. Remove the exact temporary host/firewall permits through the saved transaction. Recheck production/home isolation and normal APP1 HTTPS. Preserve the temporary-rule evidence privately; add no permanent fifth VM or fourth zone.

READ-ONLY bounded connection check - approved Windows lab source, local PowerShell, standard user. Set **$LabApprovedTarget** privately to the one approved lab-owned address/name and **$LabApprovedPort** to its single frozen port. This makes a TCP connection attempt only; it is not a scan or a protected-network probe:

```
$connection = [System.Net.Sockets.TcpClient]::new()
try {
    $attempt = $connection.ConnectAsync($LabApprovedTarget, $LabApprovedPort)
    if (-not $attempt.Wait(5000)) { throw 'Lab connection timed out.' }
    'TCP CONNECTED'
} catch {
    'NO TCP CONNECTION: ' + $_.Exception.Message
} finally {
    $connection.Dispose()
}
```

Check: the positive control prints TCP CONNECTED; a denied attempt prints NO TCP CONNECTION and has matching intended policy/log/counter evidence. A timeout alone remains inconclusive. Do not supply a home/production address, loop through ports or rerun repeatedly to force a result.

If it fails: preserve the observation, restore only the named temporary configuration under the approved plan and recheck normal access. Missing approval or working listener means NOT TESTED, not permission to broaden access.

Step 25 - Execute and record the ten tests

Purpose and location: in **03-Security-Monitoring-and-Testing.xlsx / Test Cases**, turn observed behavior into an accurate engineering record. The workbook already contains the approved methods and mandatory child checks; do not create another result template in this guide.

1. Open **Test Cases**, enable the existing table's filter and select a **Test ID**. Read its **OVERALL** row and every numbered child row, along with the authoritative Test Plan. Freeze actual source/target/user/version, approval/date, action/rate, stop/rollback and evidence ID in the linked private record.
2. Perform the approved action, compare the outcome with the expected result and obtain the separate observation described below. Enter actual result, evidence, operator/date/version and defect/retest references in the existing columns. Never enter a planned outcome as an actual result.

Test / requirement	What to do and compare
FWT-01 / FWR-01	Steps 1-6/24: compare physical/firmware inventory to readiness records; inspect cables, bridges, other adapters, routes/IPv6, trust/data/credential isolation and disconnected or approved independent egress; prove the listening mock deny with its matching policy evidence.
FWT-02 / FWR-02	Count one host/four VMs/three zones and compare measured capacity/reserves. Verify FF-01-FF-08, named admin/MFA limits, console recovery, HTTPS permit, unlisted/ordinary-user management denial and same-zone host rules against actual sessions/logs.
FWT-03 / FWR-03	Steps 8-10/15-17: inspect directory/DNS/policy/counts and standard logon; run C01-C06 with valid app credentials. Compare app file/log decisions, then prove removed eli maintenance permission denies existing/fresh requests and record actual timing.
FWT-04 / FWR-04	Steps 11-12: inspect supported builds, updates, antivirus, applied policy, host firewalls, rights, single NICs/APP1 overlay exception, listeners/forwarding. Compare a harmless standard-user admin denial with the approved admin control.
FWT-05 / FWR-05	Steps 13-16: inspect encrypted offline CA custody and leaf chain/SAN/serverAuth/constraints/dates/remaining validity. Compare the normal trusted browser session with the otherwise working client's pre-import rejection. No warning bypass or domain-time change.
FWT-06 / FWR-06	Steps 18-19/24: inspect separate tailnet/MFA/recovery/device identity, narrow additive policy, no routes/shares/SSH/Funnel/Serve and effective host/DNS rules. Demonstrate approved HTTPS, unauthorized identity, wrong listening-port/resource and existing/new revoked access, with actual times/state treatment.
FWT-07 / FWR-07	Steps 20-21: match all five event categories to real actions, source/observer times and separate policy/group observations; inspect access/rotation and explain the one denial. Keep private source records.
FWT-08 / FWR-08	Step 22: review target/private-path guard, run the one operation, compare output with OS storage, repeat and check target/path rejection. Compare before/after state; only the intended summary may change.
FWT-09 / FWR-09	Step 23: inspect encrypted off-compute backup scope/key access/time/manifest, original-off/disconnected-copy state and inactive copied overlay. Compare restore output to independent time, hashes/content and actual isolated HTTPS allow/deny; state exclusions.
FWT-10 / FWR-10	Steps 25-27: check every requirement/mandatory result/evidence/defect, five files and unchanged rubric; complete sensitive-data/publication review and engineering cutoff/verifier. Verify actual publication through the linked governance workflow and keep owner UAT separate.

3. Mark **PASS** only when the actual result and all mandatory evidence/second observations match. Mark an observed mismatch **FAIL**. Mark an unexecuted, blocked or unverified mandatory check **NOT TESTED**. A mandatory test cannot be waived with NOT APPLICABLE.
4. Set the OVERALL row to PASS only after every mandatory child passes. Preserve failures and use **04 / Issue Log** for correction/retest. Do not change an expected deny into an allow or silently replace the original evidence.
5. In **03 / Requirements Coverage**, connect all ten FWR rows to the final test/evidence/defect references. Use **Evidence Index** for private-original references and separately reviewed public artifacts; raw paths/addresses never become public links.

Check: the ten OVERALL rows and every mandatory child have an accurate verdict and traceable evidence. A second observation can be another log/UI/policy view; it is not independent human sign-off. Any missing mandatory evidence blocks engineering completion, and a critical safety failure blocks acceptance regardless of score.

If it fails: leave the affected result FAIL or NOT TESTED, explain the issue and obtain bounded remediation/retest approval. Continue only work whose dependencies remain safe; do not erase the failed attempt.

Step 26 - Finish the five Office deliverables

Purpose and location: in the private working copies of the five released templates, assemble the existing records into a clear submission. Keep detailed test execution in 03 and cross-reference it elsewhere.

1. **01-Lab-Environment-and-Architecture.xlsx:** finish **Hardware & Readiness**, **Virtual Machines**, **Network Zones**, **Allowed Network Flows** and **Resource Allocation**. Replace planned assumptions with observed fields only after verification, preserve procurement versus installation status and reference the private topology/public sanitized diagram appropriately.
2. **02-Identity-and-Zero-Trust-Implementation.docx:** complete **Implementation Overview**, **Active Directory and User Roles**, **Windows and Linux Endpoint Controls**, **Application Accounts and Permissions**, **HTTPS Certificate Configuration**, **Six Application Access Tests**, **Tailscale Remote Access**, **Access Revocation**, and **Implementation Results and Limitations**. Summarize configuration and link execution evidence in 03; do not paste password files/keys.
3. **03-Security-Monitoring-and-Testing.xlsx:** complete **Security Events**, **Denied Access Investigation**, **Test Cases**, **Requirements Coverage**, **Automation Verification**, **Backup & Restore**, and **Evidence Index**. Leave **Owner Acceptance** PENDING until explicit owner confirmation; test PASS does not fill that decision.
4. **04-Troubleshooting-and-Lessons.xlsx / Issue Log:** record actual problems, impact/cause, approved correction, verification/retest and practical lesson. Preserve unresolved items and original failure references; do not invent a troubleshooting story.
5. **05-Final-Project-Submission.docx:** complete **Executive Summary**, **Project Objectives**, **Architecture Overview**, **Implementation Summary**, **Security Testing Results**, **Key Findings**, **Challenges and Lessons Learned**, **Project Limitations**, **Final Evaluation**, and **Supporting Deliverables and Evidence**. Explain what works and what remains blocked, citing the owning records instead of copying their tables.

6. In **05 / Final Evaluation**, apply only the assignment's existing 100-point rubric: 25 infrastructure/network, 25 identity/access, 20 monitoring/operations, 20 testing/recovery and 10 documentation/submission. Record actual evaluator/date, engineering verifier and evidence cutoff. Unsupported plans earn no implementation credit.

Check: exact filenames and worksheet/section names match the blank templates, all claims point to observed evidence, limits are visible and raw private records remain outside Git. The separate project-level final report remains a template until its own real evidence/reporting is authorized.

If it fails: fix the editable working record and trace its claim to current evidence. A blank template, screenshot placeholder or total score cannot replace a mandatory test or owner acceptance.

Step 27 - Review evidence, submit and obtain owner acceptance

Purpose and location: at the approved publication workstation under L closeout scope, release only reviewed public-safe work and ask the owner to assess the intended workflows. Follow the engineering publication/build instructions and repository workflow; internal automation/branch mechanics belong there.

1. Review the whole proposed submission, not only the changed paragraph: filenames, document properties, hidden sheets/comments, screenshots, links and proposed Git history. Keep tokens/passwords, keys, hashes of passwords, actual addresses, private inventory, corporate details, raw logs/captures, backups and filled private working files outside the public set. Publish only explicitly reviewed sanitized summaries/artifacts. An ignore rule does not remove previously tracked content.
2. Capture evidence narrowly: show the relevant action/result and sanitized rule/group context. Keep source timestamps and private originals intact; review a separate redacted copy, including metadata. Do not alter the original to make a result look successful. Record reviewer/date and redaction/limitations in **03 / Evidence Index**.
3. Complete the linked documentation/report, Office-preservation, link, PDF/rebuild and focused checks for the proposed publication. Inspect the changed PDFs visually. Resolve findings and verify actual PR/CI/merge and local/remote synchronization using the established workflow; record only observed outcomes in the existing evidence record. Documentation checks do not validate lab controls.
4. Give the owner the five reviewed files and evidence index. In **03 / Owner Acceptance**, have the owner assess analyst report access, engineer maintenance access, unassigned/revoked denial, remote behavior and understandable recovery/evidence records. Record usability observations, limits/follow-ups, reviewer/date and explicit confirmation reference.
5. Keep engineering verdicts, rubric scoring and owner UAT distinct. UAT remains **PENDING** until that confirmation is supplied. Stop at the authorized boundary; do not begin another stage or project task from a publication result.

Check: the public set contains only reviewed safe material, FWT-10 has its actual required evidence, and owner acceptance accurately records the owner's decision. No CI result, score or second tool observation supplies that decision.

If it fails: stop publication on a sensitive-data finding, retain private incident evidence and use the owner's authorized revoke/rotate process if a secret was exposed. History rewriting needs separate approval. For an editorial/build defect, correct the editable source and regenerate; preserve finalized historical reports and raw evidence.

Phase 5 checkpoint and recovery

Use the acceptance criteria: all mandatory tests/subchecks need evidence and PASS for engineering completion; unresolved critical safety issues block acceptance. Owner UAT stays a separate explicit decision. Recover publication errors through reviewed corrections/reverts preserving immutable records; do not rewrite history or expand lab scope to close a report.

Required lab deliverables

These five files are **available as blank templates** in the deliverable library. Work privately, record actual results only after execution and publish only reviewed summaries. The number shorthand used throughout this manual refers to this table.

Filename	Owning record
01-Lab-Environment-and-Architecture.xlsx	Hardware, four VMs, three zones, flows and capacity
02-Identity-and-Zero-Trust-Implementation.docx	Identity, endpoints, HTTPS, app roles and remote configuration
03-Security-Monitoring-and-Testing.xlsx	Events, tests, evidence, automation, recovery and owner acceptance
04-Troubleshooting-and-Lessons.xlsx	Real issues, corrections, retests and lessons
05-Final-Project-Submission.docx	Results summary, rubric, limitations and supporting records

Historical requirement and test transition

The historical mapping appendix preserves the earlier requirement/test labels for readers following old records. It is outside the practical lab instructions and adds no current task or test. Use the current coverage index for the ten FWR/FWT mappings.